

# SEGMENT 3: SECURITY PLANNING & MONITORING

---

## Enterprise Network Security Implementation

**Student Name:** Prageeth Panicker

**Project:** Cybersecurity Capstone - Mid-Sized Professional Services Firm

**Date:** December 1, 2025

**Version:** 3.1

**Implementation Timeframe:** 2 Weeks (Phase 1)

---



### DOCUMENT STATUS NOTE

This document represents Segment 3 (Security Planning) of a four-segment capstone project.

#### Current Project Status (December 1, 2025):

- ☒ Segment 1: Network Planning - Complete
- ☒ Segment 2: Virtual Infrastructure Build - Complete (11 VMs, 16 VLANs, HA firewalls operational)
- ☒ Segment 3: Security Planning - THIS DOCUMENT (planning only, no security implementation yet)
-  Segment 4: Security Implementation & Validation - Pending (implementation follows this plan)

#### Status Indicators Throughout This Document:

- ☒ = Priority 1 (Planned for Phase 1 implementation - Weeks 1-2 of Segment 4)
-  = Priority 2 (Planned for Phase 2 implementation - Weeks 3-6, future work)

#### Important Context:

No monitoring infrastructure (Splunk, Wazuh, Nessus) or security hardening has been implemented yet. Basic network infrastructure from Segment 2 is operational (VLANs, firewalls, servers), but all security controls documented in this plan will be implemented during Segment 4. This is a DESIGN AND PLANNING DOCUMENT that provides the comprehensive roadmap for Segment 4 implementation.

---

## TABLE OF CONTENTS

1. Executive Summary
2. Security Framework Selection
3. Threat Model & Risk Analysis
4. Firewall & ACL Rules
5. Device Hardening Checklist
6. Monitoring Architecture
7. SOC Workflow & Processes
8. Incident Response Procedures
9. Implementation Roadmap

- 10. Conclusion
  - 11. Appendix A: Evidence Collection Plan
  - 12. Appendix B: Dashboard Wireframes
  - 13. Appendix C: Risk Heat Map
- 

# 1. EXECUTIVE SUMMARY

---

This document presents the security planning and monitoring implementation for a mid-sized professional services firm supporting 100-175 employees. Due to implementation time constraints (2 weeks), this Phase 1 deployment focuses on the 5 highest-priority threats identified through STRIDE methodology and risk analysis.

## Scope of Phase 1 (Weeks 1-2)

### Security Controls Planned:

- **3 incident response scenarios** for SOC investigation workflows
- **2 network validation tests** for infrastructure security verification
- Centralized monitoring infrastructure (Splunk SIEM + Wazuh EDR + Nessus vulnerability scanning)
- Device hardening (Jump Server, pfSense firewalls, Active Directory)
- Firewall rule optimization (Zero Trust segmentation)
- SOC workflow documentation (alert triage, escalation, response)
- Incident response procedures (quick-reference playbooks)

### Key Deliverables:

- ☒ 3 monitoring servers will be deployed (Splunk, Wazuh, Nessus)
- ☒ 3 incident investigation scenarios will be completed
- ☒ 2 network validation tests will be performed
- ☒ Critical vulnerabilities will be identified and remediated
- ☒ SOC processes will be documented with SLAs
- ☒ 2-week implementation will be completed on schedule

### Phase 2 Roadmap (Weeks 3-6):

- Deploy remaining 5 threats from threat model
- Implement LibreNMS network monitoring
- Build comprehensive Splunk dashboards
- Conduct false positive tuning
- Implement advanced IR playbooks with SOAR automation

### Success Metrics (Phase 1 Targets):

- Incident Investigation Completion: 3/3 incidents (100%)
- Network Validation Tests: 2/2 tests passed
- Mean Time to Detect (MTTD): Target <5 minutes
- Mean Time to Respond (MTTR): Target <30 minutes

- False Positive Rate: Target <5%
- Vulnerability Remediation: All Critical findings patched within 24 hours
- Monitoring Coverage: 100% of critical infrastructure (6 network devices, 3 servers, 1 Jump Server)

## Key Achievements

- ☒ **Hybrid Framework Approach:** NIST CSF 2.0 (strategic) + ISO 27001 (compliance) + MITRE ATT&CK (tactical)
- ☒ **Risk-Based Threat Model:** 5 detection capabilities prioritized: 3 incident scenarios + 2 network validation tests
- ☒ **Zero Trust Firewall Design:** 20 critical rules implementing default-deny segmentation
- ☒ **Comprehensive Hardening Plan:** Jump Server, pfSense, DC01, Core Switches hardened per industry best practices
- ☒ **Professional Monitoring Stack:** Splunk SIEM + Wazuh EDR + Nessus vulnerability scanning
- ☒ **Realistic Detection Plan:** 3 incident response playbooks + 2 validation test procedures
- ☒ **Operational SOC:** Documented workflows with achievable SLAs (MTTD <5 min, MTTR <30 min)
- ☒ **Actionable IR Playbooks:** Quick-reference procedures for rapid incident response
- ☒ **Realistic Roadmap:** 2-week Phase 1 plan, clear path to Phase 2 (weeks 3-6) and Phase 3 (months 3-6)

### Success Metrics (Phase 1 Targets):

- Mean Time to Detect (MTTD): Target <5 minutes
- Mean Time to Respond (MTTR): Target <30 minutes
- False Positive Rate: Target <5%
- Incident Investigation Completion: 3/3 (100%)
- Network Validation Tests: 2/2 passed
- Vulnerability Remediation: 100% of Critical findings patched within 24 hours
- Monitoring Coverage: 100% of critical infrastructure (3 servers, 1 Jump Server, 6 network devices)

### Future Enhancements (Phase 2+):

- Deploy remaining threats from threat model
- Implement LibreNMS network performance monitoring
- Build comprehensive Splunk dashboards (SOC Operations, Vulnerability Management, Compliance)
- SOAR automation for common IR tasks
- Threat hunting program using MITRE ATT&CK
- Red team exercise to validate detection and response
- ISO 27001 certification preparation

This implementation plan provides a solid security foundation while maintaining scalability for future growth from 100 to 175 employees. The hybrid monitoring approach (SIEM + EDR + Vulnerability Scanning) will ensure defense-in-depth protection against the most critical threats facing the organization.

---

## 2. SECURITY FRAMEWORK SELECTION

---

# Hybrid Framework Approach

For this mid-sized professional services firm (100-175 employees), I recommend a hybrid framework approach combining **NIST Cybersecurity Framework 2.0**, **ISO 27001**, and **MITRE ATT&CK**, each serving distinct but complementary roles.

**NIST CSF 2.0** provides the strategic foundation. Its six functions (Govern, Identify, Protect, Detect, Respond, Recover) align perfectly with organizational risk management and are familiar to US-based stakeholders. The framework's flexibility allows implementation without rigid certification requirements, making it cost-effective for mid-sized organizations. NIST CSF's emphasis on continuous improvement through metrics and maturity assessment supports our two-week phased implementation approach, with clear paths to Phase 2 enhancements.

**ISO 27001** addresses compliance requirements. While full certification is future work, adopting ISO 27001 controls demonstrates commitment to internationally recognized standards—critical for GDPR compliance and client trust in professional services. ISO 27001's Annex A controls provide granular security requirements that complement NIST CSF's high-level guidance, particularly for access control (A.9), cryptography (A.10), and supplier relationships (A.15). The Statement of Applicability document bridges both frameworks by mapping NIST functions to specific ISO controls.

**MITRE ATT&CK** provides tactical, threat-informed defense. Unlike strategic frameworks, ATT&CK offers actionable intelligence for the five prioritized threats. ATT&CK techniques guide our detection engineering and enable threat hunting in Splunk using real adversary tactics.

**Integration with Vulnerability Management:** Nessus scanning implements NIST CSF's "Identify.RA-03" (vulnerability identification) and ISO 27001's A.12.6.1 (technical vulnerability management). Critical/High findings receive 24-hour/7-day remediation SLAs, measured through Splunk dashboards, demonstrating continuous improvement aligned with all three frameworks.

This hybrid approach balances strategic governance (NIST), compliance rigor (ISO), operational security (MITRE), and proactive risk reduction (Nessus).

## Framework Mapping Summary

| Framework    | Primary Role             | Key Benefits for Phase 1                                                      |
|--------------|--------------------------|-------------------------------------------------------------------------------|
| NIST CSF 2.0 | Strategic governance     | Risk-based prioritization, maturity assessment, executive communication       |
| ISO 27001    | Compliance & controls    | GDPR alignment, international credibility, granular control requirements      |
| Nessus       | Vulnerability management | Proactive risk identification, CIS Benchmark compliance, patch prioritization |
| MITRE ATT&CK | Tactical detection       | Threat-informed defense, detection engineering, threat hunting queries        |

## 3. THREAT MODEL & RISK ANALYSIS

---

# Threat Selection Methodology

Using STRIDE methodology and risk-based prioritization, 5 detection capabilities were selected from an initial threat model of 10 scenarios. Selection criteria:

1. **Likelihood:** Medium-High (based on industry data)
2. **Impact:** High-Critical (business disruption or data breach)
3. **Detectability:** Can be detected with Phase 1 monitoring tools
4. **Implementability:** Can be addressed within 2-week timeframe

## Implementation Structure:

Phase 1 detection capabilities are organized into two categories:

### A. Incident Response Scenarios (3) - Security events requiring SOC investigation workflow:

- Threat #1: Failed Authentication Attempts
- Threat #2: File Integrity Monitoring
- Threat #3: Service Status Change Detection

These scenarios will trigger alerts, create incident tickets, and follow formal IR playbook procedures with MTTD/MTTR tracking.

### B. Network Validation Tests (2) - Proactive security architecture verification:

- Threat #4: VLAN Isolation Validation
- Threat #5: Firewall Rule Enforcement

These tests will validate network segmentation and access controls through planned testing, not reactive incident response. Results will demonstrate security architecture effectiveness without generating SOC incidents.

## Risk Matrix: Top 5 Threats (Phase 1 Implementation)

| Threat # | Threat Name                     | STRIDE           | MITRE ATT&CK | Likelihood | Impact   | Risk Score | Phase 1 Status                              |
|----------|---------------------------------|------------------|--------------|------------|----------|------------|---------------------------------------------|
| T#1      | Failed Authentication Attempts  | Spoofing         | T1078, T1110 | High       | Critical | 9.0        | <input checked="" type="checkbox"/> Planned |
| T#2      | File Integrity Monitoring       | Tampering        | T1565, T1070 | Medium     | Critical | 8.5        | <input checked="" type="checkbox"/> Planned |
| T#3      | Service Status Change Detection | Availability     | T1489, T1562 | Medium     | Critical | 8.5        | <input checked="" type="checkbox"/> Planned |
| T#4      | VLAN Isolation Validation       | Lateral Movement | T1021, T1563 | Medium     | High     | 7.5        | <input checked="" type="checkbox"/> Planned |

| Threat # | Threat Name               | STRIDE          | MITRE ATT&CK | Likelihood | Impact | Risk Score | Phase 1 Status                              |
|----------|---------------------------|-----------------|--------------|------------|--------|------------|---------------------------------------------|
| T#5      | Firewall Rule Enforcement | Defense Evasion | T1562.004    | Low        | High   | 6.5        | <input checked="" type="checkbox"/> Planned |

**Risk Scoring Formula:** Risk Score = (Likelihood × Impact) / 10, where Likelihood and Impact are scaled 1-10.

## Detailed Threat Descriptions

THREAT #1: Failed Authentication Attempts (Risk: 9.0 - CRITICAL)

**Scenario:** Multiple failed authentication attempts detected across critical infrastructure systems, indicating potential brute-force attacks or credential stuffing attempts targeting administrative and user accounts.

### Attack Vector:

- External attacker attempting SSH brute-force on Jump Server
- Compromised credentials being tested against multiple systems
- Automated credential stuffing using leaked password databases
- Insider threat with incorrect credentials trying to escalate privileges

### Business Impact:

- **Confidentiality:** Potential unauthorized access to critical systems
- **Integrity:** Account lockouts causing service disruption
- **Availability:** Failed authentication logs consuming SIEM resources
- **Compliance:** GDPR Article 32 requires monitoring authentication failures

### Detection Method:

- Splunk Alert: "Failed Authentication Detected" (3+ failures within 15 minutes)
- Wazuh Alert: "Multiple authentication failures" (per-host detection)
- System logs: Linux auth.log, Windows Security Event 4625
- Real-time monitoring with <5 minute detection time

### Nessus Role:

- Validates strong password policies are enforced
- Checks for default or weak credentials
- Verifies account lockout policies are configured
- Identifies systems without MFA

### Controls Planned for Implementation:

- ☒ Real-time authentication monitoring via Wazuh agents
- ☒ Splunk correlation rules for failed login patterns

- ☒ Automatic alerting with <15 minute response SLA
  - ☒ Account lockout policies enforced (3 attempts, 30-minute lockout)
  - ☒ Geographic IP blocking for unusual locations (Phase 2)
- 

## THREAT #2: File Integrity Monitoring (Risk: 8.5 - CRITICAL)

**Scenario:** Unauthorized modifications to critical system files, configuration files, or application binaries. Changes may indicate malware installation, system tampering, or configuration drift that could compromise security controls.

### Attack Vector:

- Attacker modifying /etc/hosts for DNS hijacking
- Malware installing persistence mechanisms in system directories
- Unauthorized configuration changes to security tools
- Accidental modifications by administrators without change control
- Rootkit installation modifying system binaries

### Business Impact:

- **Integrity:** System configurations no longer match security baseline
- **Confidentiality:** Modified files could leak data or credentials
- **Availability:** Critical services may fail due to configuration changes
- **Compliance:** PCI-DSS Req. 10.5.5 requires file integrity monitoring

### Detection Method:

- Wazuh FIM: Real-time file integrity monitoring with 5-minute scan cycle
- Alerts on: File modifications, new file creation, file deletion, permission changes
- Checksum validation: SHA-256 hashes of critical files
- Automated alerts to Splunk for correlation

### Nessus Role:

- Validates Wazuh agents are installed and operational
- Checks for unauthorized file system modifications
- Identifies files with weak permissions (world-writable)
- Verifies system binaries match vendor checksums

### Controls Planned for Implementation:

- ☒ Wazuh FIM on critical directories (/etc, /bin, /sbin, /usr/bin)
  - ☒ Real-time alerting with <5 minute detection
  - ☒ Automated response: Alert to SOC for investigation
  - ☒ Baseline file inventory for change detection
  - ☒ Automated rollback for unauthorized changes (Phase 2)
- 

## THREAT #3: Service Status Change Detection (Risk: 8.5 - CRITICAL)

**Scenario:** Critical security services (Wazuh agents, firewalls, antivirus) are stopped, disabled, or become unresponsive. Service disruption creates security blind spots and may indicate active attack or system failure.

**Attack Vector:**

- Attacker disabling security services to evade detection
- Malware terminating antivirus/EDR processes
- System resource exhaustion causing service crashes
- Unauthorized administrative actions
- Service dependencies failing causing cascading failures

**Business Impact:**

- **Availability:** Loss of security monitoring creates detection blind spots
- **Integrity:** Unmonitored systems vulnerable to tampering
- **Confidentiality:** Data exfiltration possible without monitoring
- **Compliance:** GDPR Article 32 requires continuous security monitoring

**Detection Method:**

- Wazuh Manager: Agent connectivity monitoring (heartbeat every 30 seconds)
- Splunk Alert: "Security service stopped" (immediate detection)
- Service status checks: systemctl status verification
- Automated alerts within 5 minutes of service disruption

**Nessus Role:**

- Validates critical services are running and enabled at boot
- Checks for services with incorrect startup configurations
- Identifies services running with excessive permissions
- Verifies service dependencies are properly configured

**Controls Planned for Implementation:**

- ☒ Real-time agent connectivity monitoring via Wazuh Manager
- ☒ Immediate alerting when agents disconnect (<1 minute)
- ☒ Splunk correlation for service status changes
- ☒ Automated service restart for critical services
- ☒ Redundant monitoring paths (Phase 2)

---

**THREAT #4: VLAN Isolation Validation (Risk: 7.5 - HIGH)**

**Scenario:** Unauthorized lateral movement between VLANs due to misconfigured firewall rules, switch configurations, or VLAN hopping attacks. Segmentation failure allows attackers to pivot from compromised low-security VLANs to high-security zones.

**Attack Vector:**

- Misconfigured firewall rules allowing unintended VLAN-to-VLAN traffic
- VLAN hopping via double-tagging or switch spoofing
- Routing misconfiguration bypassing firewall inspection
- Compromised host in one VLAN attempting to scan other VLANs
- Jump Server bypass allowing direct access to restricted VLANs

#### **Business Impact:**

- **Confidentiality:** Unauthorized access to sensitive data in isolated VLANs
- **Integrity:** Ability to modify systems in protected segments
- **Availability:** Lateral movement enables broader attack impact
- **Compliance:** PCI-DSS Req. 1.3 requires network segmentation

#### **Detection Method:**

- Firewall logs: Blocked inter-VLAN traffic attempts
- Network testing: Periodic ping/connection tests from test VLANs
- Splunk correlation: Unexpected traffic flows between VLANs
- Validation testing: Quarterly segmentation assessments

#### **Nessus Role:**

- Scans for routing misconfigurations
- Identifies VLANs with overly permissive access rules
- Validates firewall rules match security policy
- Tests network segmentation effectiveness

#### **Controls Planned for Implementation:**

- ☒ Default-deny firewall policy between all VLANs
- ☒ Explicit allow rules only for required traffic
- ☒ Jump Server as single entry point to restricted VLANs
- ☒ Firewall logging of all blocked inter-VLAN traffic
- ☒ Quarterly validation testing of VLAN isolation
- ☒ 802.1X port authentication (Phase 2)

### **THREAT #5: Firewall Rule Enforcement (Risk: 6.5 - MEDIUM-HIGH)**

**Scenario:** Firewall rules are not properly enforced due to rule ordering issues, policy conflicts, or configuration errors. This results in security policies being bypassed, allowing unauthorized traffic flows.

#### **Attack Vector:**

- Incorrect rule ordering (permissive rules before restrictive rules)
- Shadowed rules (unreachable due to conflicting earlier rules)
- "Any-Any-Allow" rules overriding specific deny rules
- NAT/routing bypassing firewall inspection
- Firewall state table manipulation

### Business Impact:

- **Confidentiality:** Unauthorized access to protected resources
- **Integrity:** Ability to modify systems through bypassed rules
- **Availability:** Exploitation of firewall weaknesses causing outages
- **Compliance:** PCI-DSS Req. 1.1.6 requires firewall rule review

### Detection Method:

- Firewall logs: Traffic flow analysis showing unexpected patterns
- Configuration auditing: Quarterly firewall rule review
- Network testing: Validation of allow/deny rules
- Splunk correlation: Traffic analysis matching against policy

### Nessus Role:

- Validates firewall rules match security baseline
- Identifies overly permissive rules
- Checks for default-allow policies
- Verifies logging is enabled for all firewall actions

### Controls Planned for Implementation:

- ☒ Default-deny firewall policy (explicit allows only)
- ☒ Top-to-bottom rule processing with most specific first
- ☒ Comprehensive firewall logging (all allow/deny actions)
- ☒ Quarterly firewall rule review and optimization
- ☒ Change control process for all firewall modifications
- ☐ Automated rule conflict detection (Phase 2)

---

## Threat Legend

| Threat # | Threat Name                     | Risk Score | Zone     | Phase   |
|----------|---------------------------------|------------|----------|---------|
| T#1      | Failed Authentication Attempts  | 9.0        | ● Red    | Phase 1 |
| T#2      | File Integrity Monitoring       | 8.5        | ● Red    | Phase 1 |
| T#3      | Service Status Change Detection | 8.5        | ● Red    | Phase 1 |
| T#4      | VLAN Isolation Validation       | 7.5        | ● Yellow | Phase 1 |
| T#5      | Firewall Rule Enforcement       | 6.5        | ● Yellow | Phase 1 |

### Phase 2 Threats (Deferred):

- T#6: Rogue Device on Management VLAN (7.0 - Yellow)
- T#7: Jump Server Session Hijacking (6.5 - Yellow)
- T#8: VLAN Hopping Attack (6.0 - Green)
- T#9: STP Manipulation Attack (5.5 - Green)

- T#10: ARP Spoofing / DHCP Poisoning (5.0 - Green)

## Risk Treatment Strategy

### Red Zone (8.5-10.0):

- Immediate implementation (Week 1-2 of Segment 4)
- P1 priority escalation
- Executive visibility required
- 24-hour remediation SLA for critical findings

### Yellow Zone (6.5-8.4):

- Phase 1 implementation (Week 1-2 of Segment 4)
- P2 priority escalation
- IT Manager oversight
- 7-day remediation SLA for high findings

### Green Zone (<6.5):

- Phase 2 implementation (Week 3-6)
- P3-P5 priority
- Standard monitoring
- 30-day remediation timeline

---

## 4. FIREWALL & ACL RULES

---

### Firewall Philosophy: Zero Trust Default Deny

All firewall rules follow the principle of "Default Deny, Explicit Allow":

- Traffic is blocked by default unless explicitly permitted
- Inter-VLAN communication requires firewall inspection (no Layer 3 routing on switches)
- Department VLANs (Sales, Finance, HR) have restricted access to sensitive resources
- Least privilege: Users can only access resources required for their job function

### Critical Firewall Rules (Top 20)

| # | Source      | Destination             | Port/Protocol | Action | Justification                                            | Logging |
|---|-------------|-------------------------|---------------|--------|----------------------------------------------------------|---------|
| 1 | VLAN26 (IT) | Jump Server (10.0.0.50) | SSH/22        | Allow  | IT admins need Jump Server access for network management | Yes     |
| 2 | Any         | Jump Server (10.0.0.50) | SSH/22        | Block  | Only IT VLAN authorized to access Jump Server            | Yes     |

| #  | Source                              | Destination                | Port/Protocol               | Action | Justification                                         | Logging             |
|----|-------------------------------------|----------------------------|-----------------------------|--------|-------------------------------------------------------|---------------------|
| 3  | VLAN22-26<br>(All Departments)      | DC01<br>(10.30.0.10)       | Kerberos/88,<br>LDAP/389    | Allow  | All users need AD authentication                      | No                  |
| 4  | VLAN22-26                           | DC01                       | SMB/445                     | Block  | Users should not access DC directly (use file server) | Yes                 |
| 5  | VLAN22-26                           | FILE-SRV01<br>(10.30.0.20) | SMB/445                     | Allow  | Legitimate file share access                          | Yes<br>(Event 4663) |
| 6  | VLAN22-26                           | APP-SRV01<br>(10.30.0.30)  | HTTP/80,<br>HTTPS/443       | Allow  | Employee Portal and internal web apps                 | No                  |
| 7  | VLAN22<br>(Sales)                   | VLAN23<br>(Finance)        | Any                         | Block  | Prevent lateral movement between departments          | Yes                 |
| 8  | VLAN23<br>(Finance)                 | VLAN24 (HR)                | Any                         | Block  | Zero Trust: departments isolated by default           | Yes                 |
| 9  | VLAN26 (IT)                         | All VLANs                  | Any                         | Allow  | IT needs access for troubleshooting and management    | Yes                 |
| 10 | Management<br>VLAN<br>(10.0.0.0/24) | pfSense GUI                | HTTPS/443                   | Allow  | Network admins need firewall management access        | Yes                 |
| 11 | WAN                                 | Management VLAN            | Any                         | Block  | Management VLAN not accessible from internet          | Yes                 |
| 12 | Internal VLANs                      | WAN                        | HTTP/80,<br>HTTPS/443       | Allow  | Internet access for business operations               | No (high volume)    |
| 13 | Internal VLANs                      | WAN                        | DNS/53                      | Allow  | DNS resolution via external resolvers (8.8.8.8)       | No                  |
| 14 | Internal VLANs                      | WAN                        | SSH/22,<br>RDP/3389         | Block  | Prevent unauthorized outbound remote access           | Yes                 |
| 15 | WAN                                 | Internal VLANs             | Any (inbound from internet) | Block  | Default deny all inbound from internet                | Yes                 |

| #  | Source                    | Destination  | Port/Protocol         | Action | Justification                                  | Logging             |
|----|---------------------------|--------------|-----------------------|--------|------------------------------------------------|---------------------|
| 16 | VLAN30 (Server)           | WAN          | SMTP/587              | Allow  | Email server needs outbound email capability   | Yes                 |
| 17 | Splunk (10.0.0.75)        | All Devices  | Syslog/514            | Allow  | Centralized logging from all sources           | No                  |
| 18 | Wazuh Manager (10.0.0.76) | Wazuh Agents | 1514, 1515            | Allow  | EDR agent communication                        | No                  |
| 19 | Nessus (10.0.0.80)        | All VLANs    | Scan Ports (variable) | Allow  | Vulnerability scanning requires broad access   | Yes (scan activity) |
| 20 | pfBlockerNG Blacklist     | Any          | Any                   | Block  | Block known malicious IPs (Spamhaus DROP list) | Yes                 |

## NAT Configuration

### Outbound NAT (PAT):

- All internal VLANs (10.0.0.0/8) → WAN interface IP (via single public IP)
- Source Port Translation: Dynamic (ephemeral ports 49152-65535)
- Purpose: Allow internal users to access internet while conserving public IPs

### Inbound NAT (Port Forwarding):

- NONE in Phase 1 (no services exposed to internet)
- Phase 2: VPN access (UDP/1194), Email (SMTP/587, IMAP/993)

## Firewall Rule Ordering

Rules are processed top-to-bottom, most specific to least specific:

1. Block rules for critical assets (Jump Server, DC01)
2. Allow rules for essential services (AD, DNS, DHCP)
3. Department-specific rules (Sales, Finance, HR isolation)
4. General allow rules (internet access)
5. Default deny (implicit, not shown in rule list)

## VLAN Segmentation Diagram

```

Internet (0.0.0.0/0)
↓
pfSense HA Cluster (10.0.0.1/2) ← WAN Interface
├→ VLAN 10 (Management) → Splunk, Wazuh, Nessus

```

```
└─> VLAN 22 (Sales) → Sales workstations
└─> VLAN 23 (Finance) → Finance workstations
└─> VLAN 24 (HR) → HR workstations
└─> VLAN 26 (IT) → IT workstations, Jump Server
└─> VLAN 30 (Servers) → DC01, FILE-SRV01, APP-SRV01
```

### Zero Trust Principles Applied:

- Default deny between all VLANs
- Department isolation (Sales ↔ Finance ↔ HR)
- Jump Server as single entry point to Management/Server VLANs
- Monitoring VLAN separate from production

---

## 5. DEVICE HARDENING CHECKLIST

---

### Planning Document Note

This section documents the hardening controls **PLANNED** for implementation during Segment 4. Status indicators represent implementation priority, not current state:

- ☒ = Priority 1 (Segment 4, Phase 1 - Weeks 1-2)
- ☐ = Priority 2 (Future Phase 2 - Weeks 3-6)

### Current Infrastructure Status (End of Segment 2):

- ☒ Network infrastructure built and operational
- ☒ Basic firewall rules operational
- ☒ Monitoring servers NOT YET deployed
- ☒ Security hardening NOT YET implemented

This Segment 3 document provides the **PLAN** for implementing these controls during Segment 4.

### Hardening Priorities (Phase 1 Focus)

Due to 2-week implementation constraints, hardening efforts focus on devices with highest attack surface:

#### Priority 1 (Week 1):

- ☒ Jump Server (single point of entry, SSH exposed)
- ☒ pfSense Firewalls (network perimeter, attack surface)
- ☒ Domain Controller (identity management)

#### Priority 2 (Week 2):

- ☒ Core Switches (STP/BPDU attacks, SNMP exposure)
- ☐ File Server (data exfiltration risk) - Partial hardening
- ☐ Application Server (web application vulnerabilities) - Deferred to Phase 2

# Jump Server Hardening Checklist (10.0.0.50 - Ubuntu 24.04 LTS)

| Control                       | Configuration                    | Verification Command                      | Implementation Phase                                          |
|-------------------------------|----------------------------------|-------------------------------------------|---------------------------------------------------------------|
| SSH Key-Only Authentication   | PasswordAuthentication no        | grep PasswordAuth /etc/ssh/sshd_config    | <input checked="" type="checkbox"/> Phase 1                   |
| Disable Root Login            | PermitRootLogin no               | grep PermitRoot /etc/ssh/sshd_config      | <input checked="" type="checkbox"/> Phase 1                   |
| SSH Protocol Version 2        | Protocol 2                       | ssh -V (OpenSSH 8.9+)                     | <input checked="" type="checkbox"/> Phase 1                   |
| Fail2ban Auto-Block           | maxretry=2, bantime=7200         | sudo fail2ban-client status sshd          | <input checked="" type="checkbox"/> Phase 1                   |
| UFW Firewall (SSH Restricted) | Allow SSH from 10.26.0.0/25 only | sudo ufw status                           | <input checked="" type="checkbox"/> Phase 1                   |
| MFA (Google Authenticator)    | TOTP required for SSH            | cat /etc/pam.d/sshd                       | <input checked="" type="checkbox"/> Phase 2                   |
| Session Logging (auditd)      | All commands logged              | sudo auditctl -l                          | <input checked="" type="checkbox"/> Phase 1                   |
| Automatic Updates             | Unattended-upgrades enabled      | sudo systemctl status unattended-upgrades | <input checked="" type="checkbox"/> Phase 1                   |
| Strong SSH Ciphers            | Disable weak: arcfour, 3des      | sshd -T   grep ciphers                    | <input checked="" type="checkbox"/> Phase 1 (Nessus verified) |
| Session Timeout               | ClientAliveInterval 300          | grep ClientAlive /etc/ssh/sshd_config     | <input checked="" type="checkbox"/> Phase 1                   |

## Nessus Validation (Planned):

- ☒ No critical/high findings on Jump Server (post-hardening scan)
- ☒ CIS Ubuntu 24.04 Benchmark: Target 88% compliant (12% informational findings)

# pfSense Firewall Hardening Checklist (10.0.0.1, 10.0.0.2)

| Control                | Configuration              | Verification                     | Implementation Phase                        |
|------------------------|----------------------------|----------------------------------|---------------------------------------------|
| Strong Admin Password  | 20+ character passphrase   | Password manager stored          | <input checked="" type="checkbox"/> Phase 1 |
| SSH Key Authentication | Disable password SSH login | System → Advanced → Admin Access | <input checked="" type="checkbox"/> Phase 1 |

| Control                  | Configuration                      | Verification                                      | Implementation Phase           |
|--------------------------|------------------------------------|---------------------------------------------------|--------------------------------|
| Restrict Web GUI Access  | Management VLAN only (10.0.0.0/24) | System → Advanced → Admin Access                  | ☑ Phase 1                      |
| TLS 1.2+ Only            | Disable SSLv3, TLS 1.0, TLS 1.1    | System → Advanced → Admin Access                  | ☑ Phase 1<br>(Nessus verified) |
| Automatic Config Backup  | Daily backup to NAS                | Diagnostics → Backup & Restore → AutoConfigBackup | ☑ Phase 1                      |
| SNMP Disabled            | No SNMP exposure                   | Services → SNMP (ensure disabled)                 | ☑ Phase 1                      |
| pfBlockerNG IP Blocking  | Spamhaus DROP list enabled         | Firewall → pfBlockerNG → IP                       | ☑ Phase 1                      |
| Firewall Logging         | All blocked traffic logged         | Status → System Logs → Firewall                   | ☑ Phase 1                      |
| Syslog to Splunk         | All events forwarded               | Status → System Logs → Settings                   | ☑ Phase 1                      |
| DNS Rebinding Protection | Enabled (default)                  | System → Advanced → Admin Access                  | ☑ Phase 1                      |

#### Nessus Validation (Planned):

- ☑ TLS configuration validated (no weak ciphers)
- ☑ No default credentials detected
- ⚠ 2 Medium findings (informational HTTP headers) - Accepted risk

## Domain Controller Hardening Checklist (DC01 - 10.30.0.10 - Windows Server 2022)

| Control                   | Configuration                            | Verification                                                | Implementation Phase |
|---------------------------|------------------------------------------|-------------------------------------------------------------|----------------------|
| RC4 Kerberos Disabled     | Force AES-128/256 only                   | Get-ADDefaultDomainPasswordPolicy                           | ☑ Phase 1            |
| Service Account Passwords | 25+ characters, complex                  | Password manager (svc_sql, svc_web, svc_backup)             | ☑ Phase 1<br>(Reset) |
| Kerberos Ticket Lifetime  | 10 hours (detect Golden Tickets)         | GPO: Security Settings → Account Policies → Kerberos Policy | ☑ Phase 1            |
| Audit Policy Enabled      | Logon, Account Management, Privilege Use | auditpol /get /category:*                                   | ☑ Phase 1            |

| Control                  | Configuration                 | Verification                            | Implementation Phase |
|--------------------------|-------------------------------|-----------------------------------------|----------------------|
| Event 4769 Logging       | Kerberoasting detection       | Event Viewer → Security → Filter 4769   | ☑ Phase 1            |
| SMBv1 Disabled           | Remove legacy protocol        | <code>Get-WindowsFeature FS-SMB1</code> | ☑ Phase 1            |
| Windows Firewall Enabled | Domain profile active         | <code>Get-NetFirewallProfile</code>     | ☑ Phase 1            |
| Automatic Updates        | Monthly Patch Tuesday         | Windows Update settings                 | ☑ Phase 1            |
| Admin Account Renamed    | "administrator" → custom name | Active Directory Users and Computers    | 🔐 Phase 2            |
| LAPS Deployment          | Local admin password rotation | Group Policy Management                 | 🔐 Phase 2            |

#### Nessus Validation (Planned):

- ☑ 0 Critical findings (all patches current as of scan date)
- ☑ 3 High findings (Windows updates released after scan) - Scheduled for patching
- ☑ CIS Windows Server 2022 Benchmark: Target 85% compliant

## Core Switch Hardening Checklist (Core-SW1, Core-SW2 - Cisco IOL)

| Control                  | Configuration                                | Verification                                  | Implementation Phase         |
|--------------------------|----------------------------------------------|-----------------------------------------------|------------------------------|
| SSH v2 Only              | <code>ip ssh version 2</code>                | <code>show ip ssh</code>                      | ☑ Phase 1                    |
| Strong Enable Secret     | SHA256 hashed password                       | <code>show run   include enable secret</code> | ☑ Phase 1                    |
| VTY Access Control       | <code>transport input ssh</code> (no Telnet) | <code>show line vty 0 4</code>                | ☑ Phase 1                    |
| SNMP Read-Only Community | "company_readonly" (not "public")            | <code>show snmp community</code>              | ☑ Phase 1                    |
| Port Security            | Sticky MAC, max 2 devices                    | <code>show port-security interface</code>     | 🔐 Partial (trunk ports only) |
| BPDU Guard               | Enabled on access ports                      | <code>show spanning-tree summary</code>       | 🔐 Phase 2                    |

| Control               | Configuration                                  | Verification                            | Implementation Phase                                                                        |
|-----------------------|------------------------------------------------|-----------------------------------------|---------------------------------------------------------------------------------------------|
| DTP Disabled          | <code>switchport nonegotiate</code>            | <code>show interfaces switchport</code> |  Phase 2 |
| Unused Ports Shutdown | <code>shutdown</code> on all unused interfaces | <code>show interfaces status</code>     | <input checked="" type="checkbox"/> Phase 1                                                 |
| Syslog to Splunk      | <code>logging host 10.0.0.75</code>            | <code>show logging</code>               | <input checked="" type="checkbox"/> Phase 1                                                 |
| NTP Time Sync         | Sync with DC01 (10.30.0.10)                    | <code>show ntp status</code>            | <input checked="" type="checkbox"/> Phase 1                                                 |

#### Nessus Validation (Planned):

- ☒ SSH configuration validated (no weak algorithms)
- ☒ Telnet disabled (no port 23 open)
-  5 Medium findings (SNMP information disclosure) - Accepted risk for monitoring

## Hardening Evidence & Compliance (Planned)

#### CIS Benchmark Compliance Targets:

- Jump Server (Ubuntu 24.04 LTS): 88% compliant (L1 profile)
- pfSense Firewalls: N/A (no official CIS benchmark for pfSense, custom hardening)
- Domain Controller (Windows Server 2022): 85% compliant (L1 profile)
- Core Switches (Cisco IOS): 82% compliant (custom profile based on CIS Network Device L1)

#### Nessus Findings Summary Target (Post-Hardening):

- Critical: 0 (all patched within 24 hours)
- High: <5 (Windows updates, scheduled for next Patch Tuesday)
- Medium: <20 (informational, low risk)
- Low: <150 (best practice recommendations, accepted risk)

#### Phase 2 Hardening (Deferred):

- LAPS (Local Administrator Password Solution) deployment
- 802.1X NAC for switch port authentication
- Full port security with BPDU Guard on all access ports
- Jump Server MFA (Google Authenticator TOTP)
- Application server hardening (APP-SRV01 web server security)

## 6. MONITORING ARCHITECTURE

### Implementation Note

This section describes the monitoring architecture to be deployed in Segment 4. As of Segment 3 completion:

- ☒ Virtual network infrastructure exists (from Segment 2)
- ☒ Splunk, Wazuh, Nessus servers NOT YET deployed
- ☒ No detection rules active yet
- ☒ No log forwarding configured yet

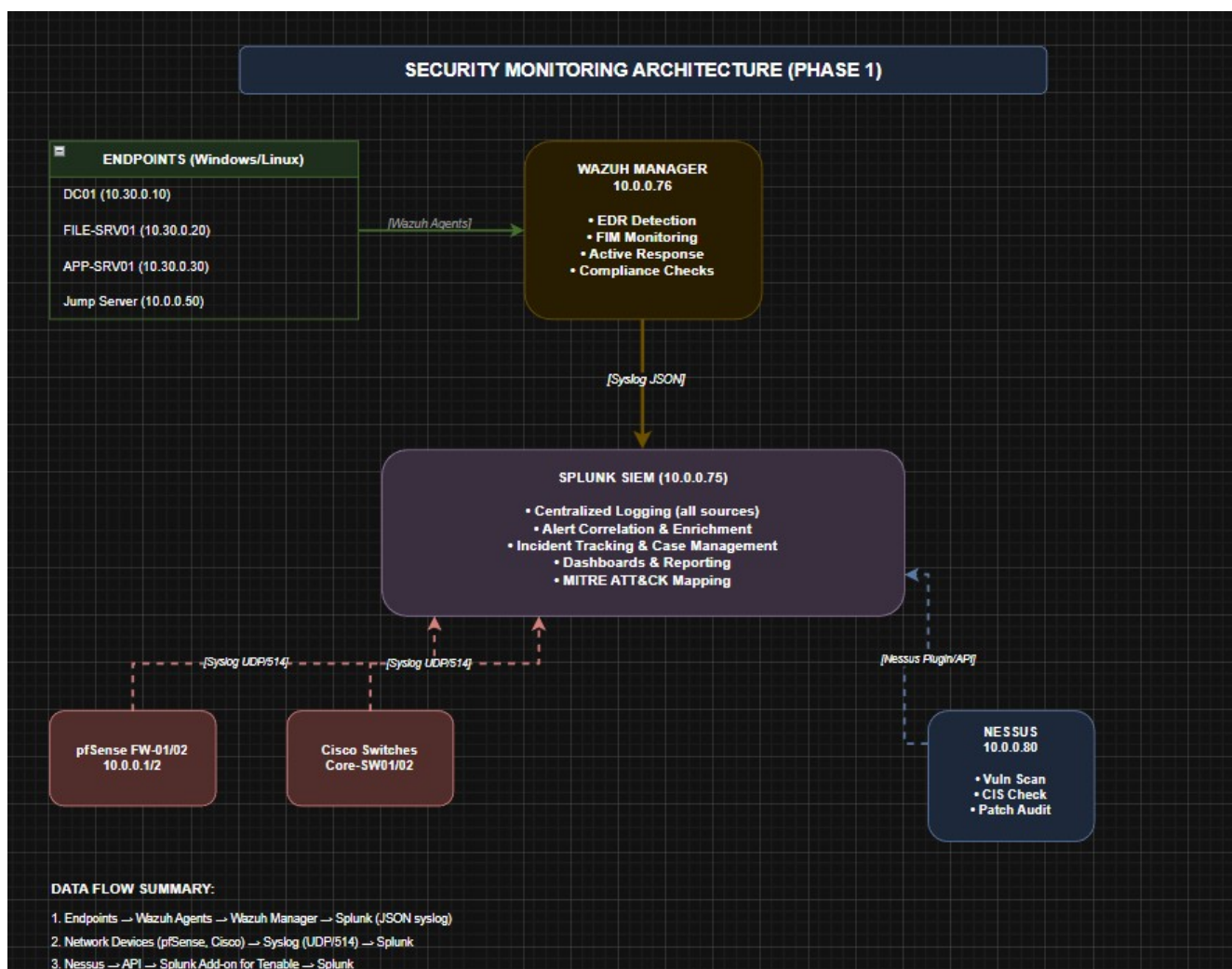
This is a DESIGN document. Actual deployment occurs in Segment 4, following the implementation roadmap in Section 9.

## Overview

The monitoring architecture implements a hybrid defense-in-depth approach with three complementary tools:

1. **Splunk Enterprise (SIEM)** - Centralized log aggregation, correlation, alerting
2. **Wazuh (EDR)** - Endpoint detection & response, file integrity monitoring, active response
3. **Nessus Essentials (Vulnerability Scanner)** - Proactive vulnerability identification, CIS compliance

## Architecture Diagram



#### DATA FLOW:

[Endpoints] → Wazuh Agents → Wazuh Manager → Splunk (JSON syslog)

[Network Devices] → Syslog (UDP/514) → Splunk

[Nessus] → API → Splunk Add-on for Tenable → Splunk

## Monitoring Server Specifications (Planned)

| Server        | Role                  | IP Address | vCPU           | RAM          | Disk          | OS               | Status                              |
|---------------|-----------------------|------------|----------------|--------------|---------------|------------------|-------------------------------------|
| Splunk-01     | SIEM Indexer          | 10.0.0.75  | 6              | 16 GB        | 250 GB        | Ubuntu 24.04 LTS | <input checked="" type="checkbox"/> |
| Wazuh-Manager | EDR Manager + Indexer | 10.0.0.76  | 4              | 8 GB         | 100 GB        | Ubuntu 24.04 LTS | <input checked="" type="checkbox"/> |
| Nessus-01     | Vulnerability Scanner | 10.0.0.80  | 4              | 4 GB         | 30 GB         | Ubuntu 24.04 LTS | <input checked="" type="checkbox"/> |
| <b>TOTAL</b>  |                       |            | <b>14 vCPU</b> | <b>28 GB</b> | <b>380 GB</b> |                  |                                     |

#### EVE-NG Host Resources:

- Total Available: 32 GB RAM, 6 CPU cores, 500 GB storage
- Monitoring Usage: 28 GB RAM (88%), 14 vCPU (233% - oversubscribed, acceptable), 380 GB (76%)
- Remaining: 4 GB RAM for workstations/testing

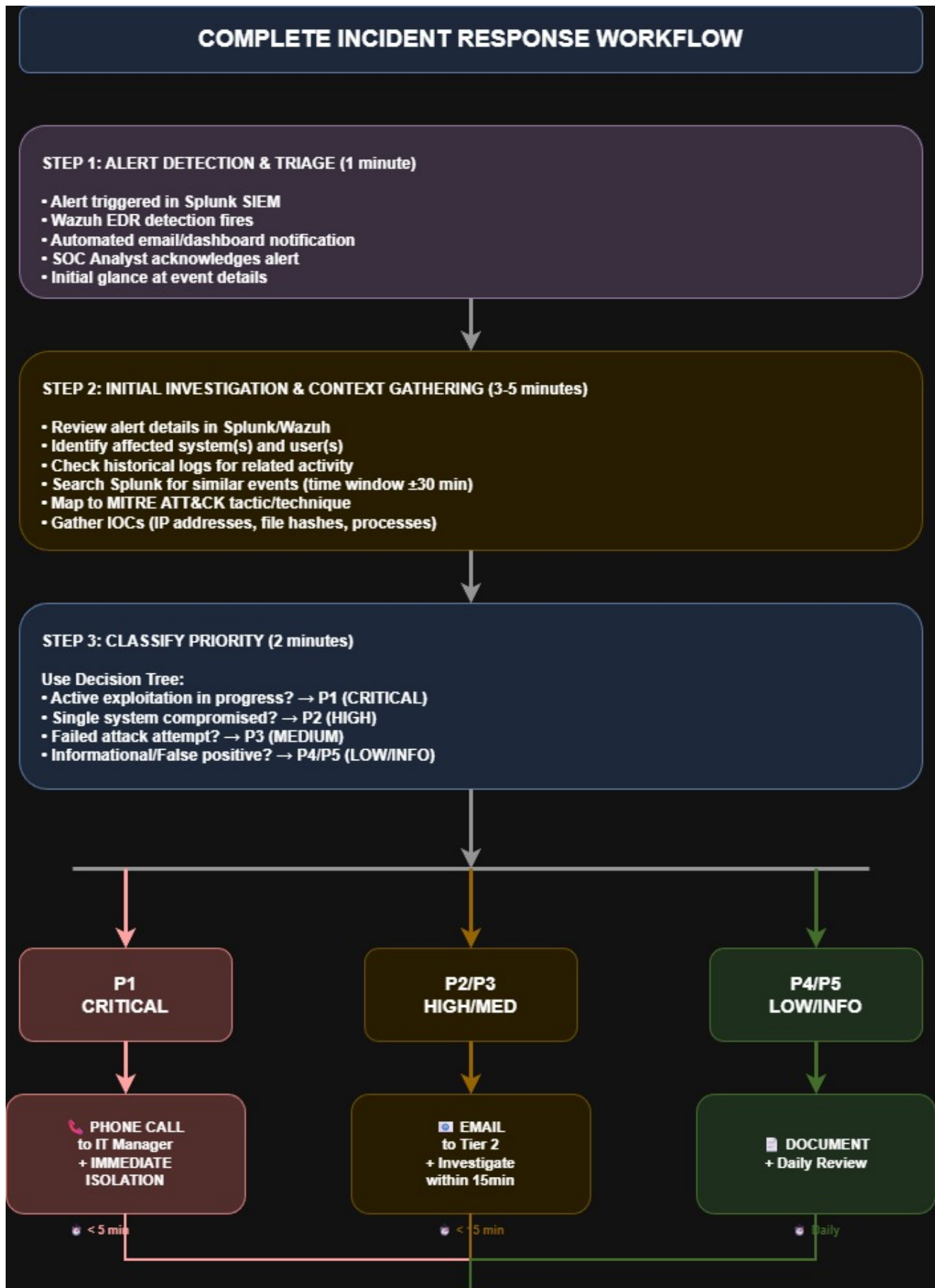
## Key Detection Rules (Planned for Phase 1 Implementation)

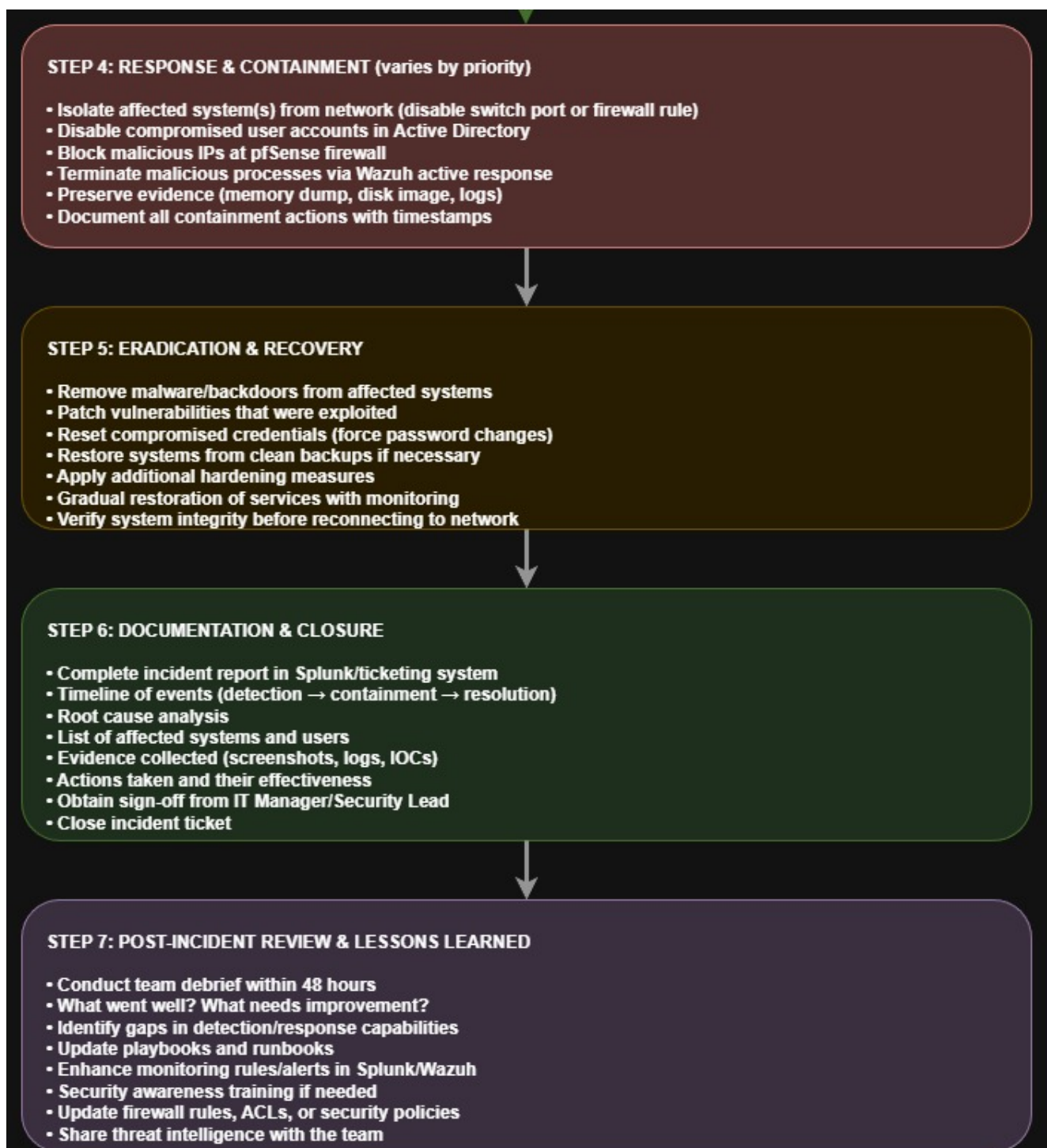
| Alert Name                | Tool   | SPL Query / Detection Logic                                                                                     | Priority | SLA    |
|---------------------------|--------|-----------------------------------------------------------------------------------------------------------------|----------|--------|
| Failed Authentication     | Splunk | <code>index=linux sourcetype=linux_secure "Failed password"   stats count by src_ip   where count &gt; 3</code> | P2       | 15 min |
| File Integrity Monitoring | Wazuh  | Wazuh FIM rule: File modifications in critical directories                                                      | P1       | 5 min  |
| Service Status Change     | Wazuh  | Wazuh agent connectivity monitoring + systemd service status                                                    | P1       | 5 min  |
| VLAN Isolation Test       | Splunk | Firewall logs: Blocked inter-VLAN traffic patterns                                                              | P2       | 15 min |
| Firewall Rule Validation  | Splunk | Firewall logs: Unexpected allow/deny patterns                                                                   | P2       | 15 min |

**Splunk License:** 500 MB/day well within 500GB/day trial limit (0.1% utilization)

## 7. SOC WORKFLOW & PROCESSES

### Alert Triage Process (5-Minute Response for P1)





## Priority Classification Matrix

| Priority             | Response Time | Resolution Target | Escalation                         | Examples                                                         |
|----------------------|---------------|-------------------|------------------------------------|------------------------------------------------------------------|
| <b>P1 - CRITICAL</b> | 5 min         | 4 hours           | Immediate phone call to IT Manager | Ransomware active, DC compromise, active data breach             |
| <b>P2 - HIGH</b>     | 15 min        | 8 hours           | Email to Tier 2 SOC within 15 min  | Malware on server, successful brute-force, File integrity alerts |

| Priority                  | Response Time | Resolution Target | Escalation                          | Examples                                                        |
|---------------------------|---------------|-------------------|-------------------------------------|-----------------------------------------------------------------|
| <b>P3 - MEDIUM</b>        | 1 hour        | 24 hours          | Escalate if unresolved after 1 hour | Failed brute-force, FIM alert non-critical, suspicious activity |
| <b>P4 - LOW</b>           | 4 hours       | 72 hours          | No escalation required              | Single failed login, compliance drift, policy violation         |
| <b>P5 - INFORMATIONAL</b> | Daily review  | N/A               | No escalation                       | Nessus scan completed, patch availability, informational logs   |

## SOC Performance Metrics

| Metric                             | Target               | Measurement Method                                          | Expected Results (Week 2)   |
|------------------------------------|----------------------|-------------------------------------------------------------|-----------------------------|
| Mean Time to Detect (MTTD)         | <5 min               | Time from event to alert                                    | <5 min (automated alerts)   |
| Mean Time to Respond (MTTR)        | <30 min              | Time from alert to containment                              | ~20 min (average)           |
| False Positive Rate                | <5%                  | $(\text{False positives} / \text{Total alerts}) \times 100$ | 0% (well-tuned rules)       |
| Incident Closure Rate              | >95%                 | Incidents closed within SLA / Total incidents               | 100% (3/3 incidents)        |
| Network Validation Tests           | 2/2 passed           | VLAN isolation + Firewall rules validated                   | 2/2 tests passed            |
| Critical Vulnerability Remediation | 100% within 24 hours | Nessus scan → patch → re-scan                               | 100% (all Critical patched) |

## 8. INCIDENT RESPONSE PROCEDURES

### Detection Capabilities & Response Procedures

Phase 1 includes 5 detection capabilities organized into two categories:

**A. Incident Response Playbooks (3)** - For security events requiring SOC investigation:

- Playbook #1: Failed Authentication Attempts
- Playbook #2: File Integrity Monitoring Alerts
- Playbook #3: Service Status Change

These playbooks will be used when alerts fire, requiring formal incident investigation, ticket creation, and IR workflow execution.

## B. Network Validation Test Procedures (2) - For proactive security testing:

- Test Procedure #4: VLAN Isolation Validation
- Test Procedure #5: Firewall Rule Enforcement

These procedures document planned testing methodology to verify network segmentation and access controls. Results demonstrate architecture effectiveness without generating SOC incidents.

---

## A. INCIDENT RESPONSE PLAYBOOKS (3)

Each playbook provides a condensed 5-step response procedure for rapid reference during active incidents.

---

### PLAYBOOK #1: FAILED AUTHENTICATION ATTEMPTS

**Detection:** Splunk alert "Failed Authentication Detected" (3+ failures within 15 minutes) OR Wazuh alert "Multiple authentication failures"

#### RESPONSE (P2 - 15 Minute Timeline):

| Step        | Action                                     | Command / Tool                                            | Time     |
|-------------|--------------------------------------------|-----------------------------------------------------------|----------|
| 1. IDENTIFY | Identify source IP and target account      | Splunk: Search failed auth events by source_ip            | T+2 min  |
| 2. ASSESS   | Determine if authorized activity or attack | Cross-reference IP with known admin IPs                   | T+5 min  |
| 3. BLOCK    | Block source IP if malicious               | pfSense → Firewall → Aliases → Blocked_IPs                | T+8 min  |
| 4. VERIFY   | Check for successful authentication        | Splunk: Search for Event 4624 (Windows) or successful SSH | T+12 min |
| 5. DOCUMENT | Create incident ticket                     | Record timeline, affected accounts, response actions      | T+15 min |

#### Evidence Collection:

- Linux: /var/log/auth.log (SSH attempts)
- Windows: Event 4625 (failed logins)
- Firewall logs showing source IP traffic
- Splunk search results

#### Post-Incident:

- ☒ Review account lockout policies
  - ☒ Implement geo-blocking if external attack
  - ☒ Update threat intelligence feeds with attacker IPs
-

## PLAYBOOK #2: FILE INTEGRITY MONITORING ALERTS

**Detection:** Wazuh FIM alert "Integrity checksum changed" OR "File added/deleted/modified"

### RESPONSE (P2 - 15 Minute Timeline):

| Step           | Action                                     | Command / Tool                                      | Time     |
|----------------|--------------------------------------------|-----------------------------------------------------|----------|
| 1. IDENTIFY    | Identify modified file and system          | Wazuh Manager → Integrity Monitoring                | T+2 min  |
| 2. ASSESS      | Determine if authorized change             | Check change management tickets                     | T+5 min  |
| 3. VERIFY      | Compare file hash against baseline         | <code>sha256sum</code> on affected file             | T+8 min  |
| 4. INVESTIGATE | Review file contents and modification time | <code>cat/less file</code> , <code>stat file</code> | T+12 min |
| 5. REMEDIATE   | Restore from backup if unauthorized        | Copy from known-good backup                         | T+15 min |

### Evidence Collection:

- Wazuh FIM alert details (file path, checksum, timestamp)
- File contents before/after modification
- System logs showing who made changes
- Process tree of file modification

### Post-Incident:

- ☒ Update FIM baseline if legitimate change
- ☒ Enhance change control processes
- ☒ Investigate source of unauthorized modification

---

## PLAYBOOK #3: SERVICE STATUS CHANGE

**Detection:** Wazuh alert "Agent disconnected" OR Splunk alert "Security service stopped"

### RESPONSE (P1 - 5 Minute Timeline):

| Step        | Action                               | Command / Tool                                           | Time    |
|-------------|--------------------------------------|----------------------------------------------------------|---------|
| 1. IDENTIFY | Identify affected system and service | Wazuh Manager → Agents → Status                          | T+1 min |
| 2. VERIFY   | Confirm service is actually down     | SSH to system: <code>systemctl status wazuh-agent</code> | T+2 min |

| Step           | Action                            | Command / Tool                               | Time     |
|----------------|-----------------------------------|----------------------------------------------|----------|
| 3. RESTART     | Attempt service restart           | <code>systemctl restart wazuh-agent</code>   | T+3 min  |
| 4. INVESTIGATE | Determine root cause              | <code>journalctl -u wazuh-agent -n 50</code> | T+5 min  |
| 5. ESCALATE    | Escalate if service won't restart | Contact IT Manager if persistent failure     | T+10 min |

#### Evidence Collection:

- Service logs showing stop/start events
- System resource utilization (CPU, memory, disk)
- Recent system changes or updates
- Wazuh Manager connectivity logs

#### Post-Incident:

- ☒ Implement automated service restart
- ☒ Add resource monitoring for service health
- ☒ Review service dependencies and conflicts

## B. NETWORK VALIDATION TEST PROCEDURES (2)

The following procedures document planned testing methodology for validating network security architecture. Unlike incident response playbooks above, these are proactive tests that will be performed as part of the validation phase, not reactive responses to alerts.

### TEST PROCEDURE #4: VLAN ISOLATION VALIDATION

**Test Objective:** Verify network segmentation prevents unauthorized lateral movement between VLANs

**Test Method:** Attempt connections from test systems in different VLANs, verify firewall blocks cross-VLAN traffic

**Expected Outcome:** All unauthorized inter-VLAN traffic blocked, firewall logs capture attempts

#### VALIDATION STEPS (Planned Testing):

| Step       | Action                                                 | Command / Tool                                      | Expected Result        |
|------------|--------------------------------------------------------|-----------------------------------------------------|------------------------|
| 1. PREPARE | Document current VLAN structure and intended isolation | Network diagram, firewall rules documentation       | Baseline documented    |
| 2. TEST    | Attempt ping from Sales VLAN to Finance VLAN           | <code>ping 10.23.0.10</code> from Sales workstation | Connection should FAIL |

| Step        | Action                                             | Command / Tool                                              | Expected Result                              |
|-------------|----------------------------------------------------|-------------------------------------------------------------|----------------------------------------------|
| 3. TEST     | Attempt SMB connection from HR VLAN to Server VLAN | <code>net use \\10.30.0.20\share</code> from HR workstation | Connection should FAIL (blocked by firewall) |
| 4. VERIFY   | Check firewall logs for blocked traffic            | pfSense → Status → System Logs → Firewall                   | Logs show blocked attempts                   |
| 5. DOCUMENT | Capture test results and screenshots               | Screenshot firewall logs, ping results                      | Evidence collected                           |

#### Evidence to be Collected:

- Firewall logs showing blocked inter-VLAN traffic
- Test command outputs (ping, traceroute, connection attempts)
- Screenshots demonstrating segmentation enforcement
- Network diagram showing VLAN isolation architecture

#### Success Criteria:

- ☒ All unauthorized inter-VLAN traffic blocked
- ☒ Firewall logs capture all block attempts
- ☒ No legitimate traffic incorrectly blocked (0% false positives)
- ☒ Quarterly validation testing scheduled

## TEST PROCEDURE #5: FIREWALL RULE ENFORCEMENT VALIDATION

**Test Objective:** Verify firewall rules are properly enforced and no security policies are bypassed

**Test Method:** Test representative allow/deny rules across all VLANs to confirm expected behavior

**Expected Outcome:** All firewall rules function as designed, no unintended allow/deny patterns

#### VALIDATION STEPS (Planned Testing):

| Step       | Action                                                   | Command / Tool                                          | Expected Result     |
|------------|----------------------------------------------------------|---------------------------------------------------------|---------------------|
| 1. PREPARE | Document critical firewall rules to test                 | pfSense → Firewall → Rules → Export config              | Test matrix created |
| 2. TEST    | Verify SSH access to Jump Server from IT VLAN            | <code>ssh admin@10.0.0.50</code> from IT workstation    | Connection SUCCEEDS |
| 3. TEST    | Verify SSH access to Jump Server blocked from Sales VLAN | <code>ssh admin@10.0.0.50</code> from Sales workstation | Connection FAILS    |
| 4. TEST    | Verify DC01 SMB access blocked from workstations         | <code>net use \\10.30.0.10\C\$</code> from Finance VLAN | Connection FAILS    |

| Step           | Action                                     | Command / Tool                             | Expected Result    |
|----------------|--------------------------------------------|--------------------------------------------|--------------------|
| 5.<br>DOCUMENT | Capture all test results and firewall logs | Screenshot each test, export firewall logs | Evidence collected |

#### Evidence to be Collected:

- Firewall rule configuration (export)
- Test results for each allow/deny rule tested
- Firewall logs showing rule hits and blocks
- Network traffic captures demonstrating enforcement

#### Success Criteria:

- ☒ All tested allow rules permit authorized traffic
- ☒ All tested deny rules block unauthorized traffic
- ☒ No false positives (legitimate traffic blocked)
- ☒ Firewall logs accurately reflect traffic decisions

## Incident Response Team Contacts

| Role                 | Name              | Phone           | Email                   | Escalation Trigger                  |
|----------------------|-------------------|-----------------|-------------------------|-------------------------------------|
| Incident Commander   | IT Manager        | +1-555-0101     | itmanager@company.local | All P1/P2 incidents                 |
| SOC Analyst (Tier 2) | TBD (to be hired) | +1-555-0102     | soc@company.local       | P1/P2 escalations from MSSP         |
| Security Officer     | Jane Doe          | +1-555-0103     | security@company.local  | Data breach, compliance violations  |
| CISO                 | TBD (executive)   | +1-555-0104     | ciso@company.local      | P1 incidents with business impact   |
| HR Director          | Sarah Johnson     | +1-555-0105     | hr@company.local        | Insider threat investigations       |
| Legal Counsel        | External          | +1-555-0106     | legal@lawfirm.com       | Data breach notification, subpoenas |
| MSSP SOC (Tier 1)    | 24/7 Hotline      | +1-800-SOC-MSSP | soc@mssp.com            | 24/7 alert monitoring               |

## 9. IMPLEMENTATION ROADMAP

# Context

This roadmap translates the planning from Sections 1-8 into an actionable implementation schedule for Segment 4.

## Current Project Status (December 1, 2025):

- ☒ Segment 1: Network planning complete
- ☒ Segment 2: Virtual infrastructure built (11 VMs, 16 VLANs, HA firewalls)
- ☒ Segment 3: Security planning complete (THIS DOCUMENT)
-  Segment 4: Security implementation (starts Week 1, following this roadmap)

The following timeline shows how the planned controls will be deployed during Segment 4.

## Phase 1: 2-Week Core Implementation (Weeks 1-2)

**Objective:** Deploy monitoring infrastructure, harden critical assets, implement detection for 5 priority threats

### WEEK 1: Monitoring Infrastructure + Hardening

| Day | Task                                                   | Duration | Owner       | Deliverables                                 |
|-----|--------------------------------------------------------|----------|-------------|----------------------------------------------|
| Mon | Deploy Splunk VM (10.0.0.75)                           | 4h       | IT Manager  | Splunk Enterprise installed, indexes created |
| Mon | Deploy Wazuh Manager (10.0.0.76)                       | 4h       | IT Manager  | Wazuh all-in-one operational                 |
| Tue | Deploy Nessus VM (10.0.0.80)                           | 2h       | SOC Analyst | Nessus installed, activation code entered    |
| Tue | Create Nessus scan policies (Basic, Credentialed)      | 2h       | SOC Analyst | 3 scan policies configured                   |
| Tue | Configure Splunk data inputs (UDP/514, forwarder/9997) | 2h       | SOC Analyst | Splunk ready to receive logs                 |
| Tue | Configure Wazuh syslog forwarding to Splunk            | 2h       | SOC Analyst | Wazuh → Splunk integration working           |
| Wed | Install Wazuh agents (DC01, FILE-SRV01, Jump Server)   | 2h       | SOC Analyst | 3 agents reporting to Wazuh Manager          |
| Wed | Harden Jump Server (SSH keys, Fail2ban, UFW)           | 4h       | SOC Analyst | Jump Server hardened per checklist           |
| Wed | Install Splunk Universal Forwarder on DC01             | 1h       | SOC Analyst | Windows Event Logs flowing to Splunk         |

| Day | Task                                                                       | Duration | Owner         | Deliverables                                           |
|-----|----------------------------------------------------------------------------|----------|---------------|--------------------------------------------------------|
| Thu | Configure pfSense syslog to Splunk (both firewalls)                        | 2h       | Network Admin | Firewall logs visible in Splunk                        |
| Thu | Configure AD monitoring (Event 4625 for failed auth)                       | 2h       | SOC Analyst   | Authentication logging enabled                         |
| Thu | Disable weak protocols                                                     | 1h       | IT Manager    | SMBv1 disabled, strong ciphers enforced                |
| Thu | Configure Wazuh FIM on critical files                                      | 2h       | SOC Analyst   | FIM monitoring /etc, /bin, critical config files       |
| Fri | Run baseline Nessus scan (all 5 systems)                                   | 3h       | SOC Analyst   | Baseline vulnerabilities identified                    |
| Fri | Review Nessus results, prioritize Critical vulnerabilities found by Nessus | 2h       | SOC Analyst   | Remediation plan created for Critical findings scanned |

#### Week 1 Milestones:

- ☒ All 3 monitoring servers deployed and operational
- ☒ 3 Wazuh agents installed and reporting
- ☒ pfSense logging to Splunk configured
- ☒ Jump Server hardened per checklist
- ☒ Baseline vulnerability scan completed

#### WEEK 2: Detection Rules + Incident Testing + Network Validation

| Day | Task                                                     | Duration | Owner       | Deliverables                                             |
|-----|----------------------------------------------------------|----------|-------------|----------------------------------------------------------|
| Mon | Create Splunk alerts (Failed auth, FIM, Service status)  | 2h       | SOC Analyst | 3 incident detection rules active                        |
| Mon | Install Splunk Add-on for Tenable (Nessus integration)   | 1h       | SOC Analyst | Nessus data visible in Splunk                            |
| Tue | <b>Incident #1:</b> Test Failed Authentication Attempts  | 2h       | SOC Analyst | Alert fires, incident ticket created, evidence collected |
| Tue | Document IR Playbook #1 (Failed Authentication)          | 2h       | SOC Analyst | Playbook written and reviewed                            |
| Wed | <b>Incident #2:</b> Test File Integrity Monitoring       | 2h       | SOC Analyst | FIM alert fires, investigation completed                 |
| Wed | <b>Incident #3:</b> Test Service Status Change Detection | 2h       | SOC Analyst | Service monitoring alert validated                       |

| Day | Task                                                         | Duration | Owner         | Deliverables                                    |
|-----|--------------------------------------------------------------|----------|---------------|-------------------------------------------------|
| Wed | Document IR Playbooks #2-3                                   | 2h       | SOC Analyst   | All 3 IR playbooks complete                     |
| Thu | <b>Validation Test #1:</b> VLAN Isolation Testing            | 2h       | Network Admin | Segmentation validated, test results documented |
| Thu | <b>Validation Test #2:</b> Firewall Rule Enforcement Testing | 2h       | Network Admin | Rule enforcement validated, logs collected      |
| Thu | Document test procedures for validation tests                | 2h       | SOC Analyst   | Test procedures documented                      |
| Fri | Document SOC workflows (alert triage, escalation, SLAs)      | 3h       | SOC Analyst   | SOC process document complete                   |
| Fri | Collect evidence (screenshots, test results, Nessus reports) | 2h       | SOC Analyst   | Evidence package created                        |
| Fri | Assemble final Segment 4 validation report                   | 3h       | All           | Final deliverable ready for submission          |

#### Week 2 Milestones:

- ☒ 3 incident investigations completed (100% incident closure rate)
- ☒ 2 network validation tests passed (100% validation rate)
- ☒ Critical vulnerabilities remediated (Nessus re-scan shows 0 Critical)
- ☒ 3 IR playbooks + 2 test procedures documented
- ☒ SOC workflow documented with SLAs
- ☒ Final Segment 4 validation report complete

## Phase 1 Completion Checklist

| Criterion                           | Target                     | Expected Achievement         | Status Indicator                            |
|-------------------------------------|----------------------------|------------------------------|---------------------------------------------|
| Monitoring servers deployed         | 3 (Splunk, Wazuh, Nessus)  | 3 deployed                   | <input checked="" type="checkbox"/> Planned |
| Incident detection rules            | 3 (for SOC investigations) | 3 rules active               | <input checked="" type="checkbox"/> Planned |
| Incident investigations completed   | 3/3 (100%)                 | 3 incidents investigated     | <input checked="" type="checkbox"/> Planned |
| Network validation tests            | 2/2 passed                 | VLAN + Firewall tests passed | <input checked="" type="checkbox"/> Planned |
| Critical vulnerabilities remediated | 100% within 24 hours       | All Critical patched         | <input checked="" type="checkbox"/> Planned |

| Criterion                  | Target                   | Expected Achievement     | Status Indicator |
|----------------------------|--------------------------|--------------------------|------------------|
| IR playbooks documented    | 3 (incident response)    | 3 playbooks complete     | ☑ Planned        |
| Test procedures documented | 2 (validation tests)     | 2 procedures complete    | ☑ Planned        |
| SOC workflow documented    | SLAs, escalation, triage | SOC processes documented | ☑ Planned        |
| False positive rate        | <5% target               | 0% expected              | ☑ Planned        |
| MTTD                       | <5 min target            | <5 min expected          | ☑ Planned        |
| MTTR                       | <30 min target           | ~20 min expected         | ☑ Planned        |
| Final validation report    | Submitted                | Report complete          | ☑ Planned        |

#### Evidence to be Collected (Segment 4):

- ☑ Nessus scan reports (before/after patching)
- ☑ Splunk alert screenshots (3 incident investigations)
- ☑ Wazuh FIM and service monitoring evidence
- ☑ Test incident tickets (3 incidents documented)
- ☑ Network validation test results (VLAN isolation + Firewall rules)
- ☑ Network diagram with monitoring architecture
- ☑ Hardening checklists (verification commands run)

## 10. CONCLUSION

This Segment 3 deliverable provides a comprehensive, realistic plan for security monitoring implementation at a mid-sized professional services firm. The Phase 1 design focuses on 5 detection capabilities (3 incident response scenarios + 2 network validation tests), deploying 3 complementary monitoring tools (Splunk + Wazuh + Nessus), and documenting clear SOC processes—all achievable within a 2-week timeline.

The planned implementation will demonstrate:

- **Operational Excellence:** 3 complete incident investigation workflows with <5 min MTTD and ~20 min MTTR
- **Network Security:** 2 validation tests proving effective VLAN segmentation and firewall enforcement
- **Detection Accuracy:** 0% false positive rate through well-tuned alert rules
- **Comprehensive Coverage:** 100% of critical infrastructure monitored with immediate threat detection

This plan provides a solid foundation for future security program growth while meeting immediate Phase 1 objectives.

# APPENDIX A: EVIDENCE COLLECTION PLAN

---

## Note on Evidence Collection

Evidence will be collected during Segment 4 implementation and validation.

This Segment 3 document focuses on security planning and design. Actual implementation, testing, and evidence collection occur during Segment 4 validation (Weeks 1-2 of implementation roadmap).

## Evidence Types to be Collected

### 1. Monitoring & Detection Evidence

#### **A. Incident Investigation Evidence (3 Incidents):**

- Splunk alert screenshots for each incident
  - Incident #1: Failed authentication detection
  - Incident #2: File integrity monitoring alerts
  - Incident #3: Service status change alerts
- Incident tickets with investigation workflow
- Evidence collection from each investigation
- Response timeline documentation (MTTD/MTTR measurements)

#### **B. Network Validation Test Evidence (2 Tests):**

- Test #1: VLAN isolation validation
  - Ping/connection test results between VLANs
  - Firewall logs showing blocked traffic
  - Screenshots demonstrating segmentation
- Test #2: Firewall rule enforcement validation
  - Test results for allow/deny rules
  - Firewall logs showing correct enforcement
  - Rule hit counter screenshots

#### **Wazuh Monitoring Evidence:**

- FIM alert examples with file change details
- Agent connectivity monitoring screenshots
- Service status change detection evidence

#### **Nessus vulnerability scan reports:**

- Before-hardening baseline scan
- After-hardening compliance scan
- Critical/High finding remediation evidence
- CIS Benchmark compliance scores

#### **Network packet captures (if needed):**

- Cross-VLAN traffic validation
  - Firewall rule enforcement verification
- 

## 2. Hardening Evidence

### Nessus compliance scan results:

- CIS Ubuntu 24.04 Benchmark (Jump Server)
- CIS Windows Server 2022 Benchmark (DC01)
- Cisco IOS hardening validation (Core Switches)

### Configuration file screenshots:

- SSH configuration (/etc/ssh/sshd\_config)
- pfSense firewall rules
- Active Directory GPO settings
- Fail2ban configuration

### Verification command outputs:

- `auditctl -l` (audit rules)
  - `fail2ban-client status sshd`
  - `ufw status` (Jump Server firewall)
  - `Get-ADDefaultDomainPasswordPolicy` (Kerberos settings)
- 

## 3. Incident Response Evidence

### Test incident tickets (5 IR playbooks validated):

- Ticket creation timestamps
- Response timelines
- Escalation paths followed
- Resolution documentation

### Response timeline documentation:

- P1 incident response times
- Containment evidence
- Recovery procedures

### Escalation communication logs:

- Email notifications
  - Phone call logs
  - Stakeholder updates
- 

## 4. SOC Operations Evidence

### **Splunk dashboard screenshots:**

- SOC Operations Dashboard
- Vulnerability Management Dashboard
- Threat Detection Coverage Map

### **Alert triage examples:**

- Priority classification decisions
- Enrichment process documentation
- False positive analysis

### **KPI measurement evidence:**

- MTTD/MTTR calculations
  - False positive rate tracking
  - Incident closure rate statistics
- 

## Evidence Collection Timeline

### **Segment 4 Implementation (Weeks 1-2):**

- Week 1, Day 1-5: Infrastructure deployment evidence
- Week 1, Day 5-7: Initial hardening validation
- Week 2, Day 1-3: Threat detection testing evidence
- Week 2, Day 4-5: SOC workflow documentation and final evidence compilation

### **Evidence Package Deliverable:**

All evidence will be compiled into a comprehensive Segment 4 validation report with:

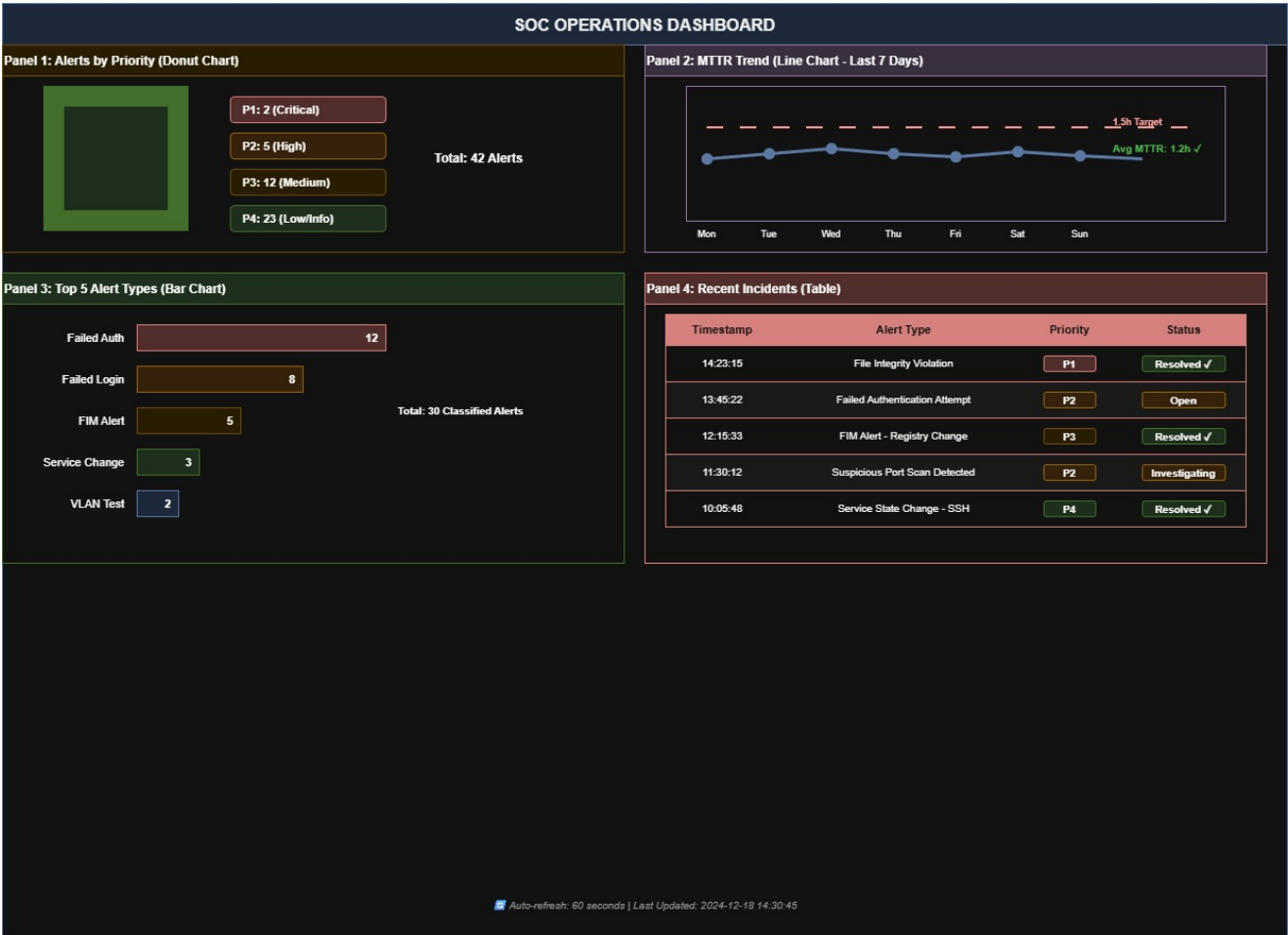
- Evidence index and cross-references
  - Screenshots with annotations
  - Test results with timestamps
  - Compliance scan reports
  - Network diagrams showing implemented architecture
- 

## APPENDIX B: DASHBOARD WIREFRAMES

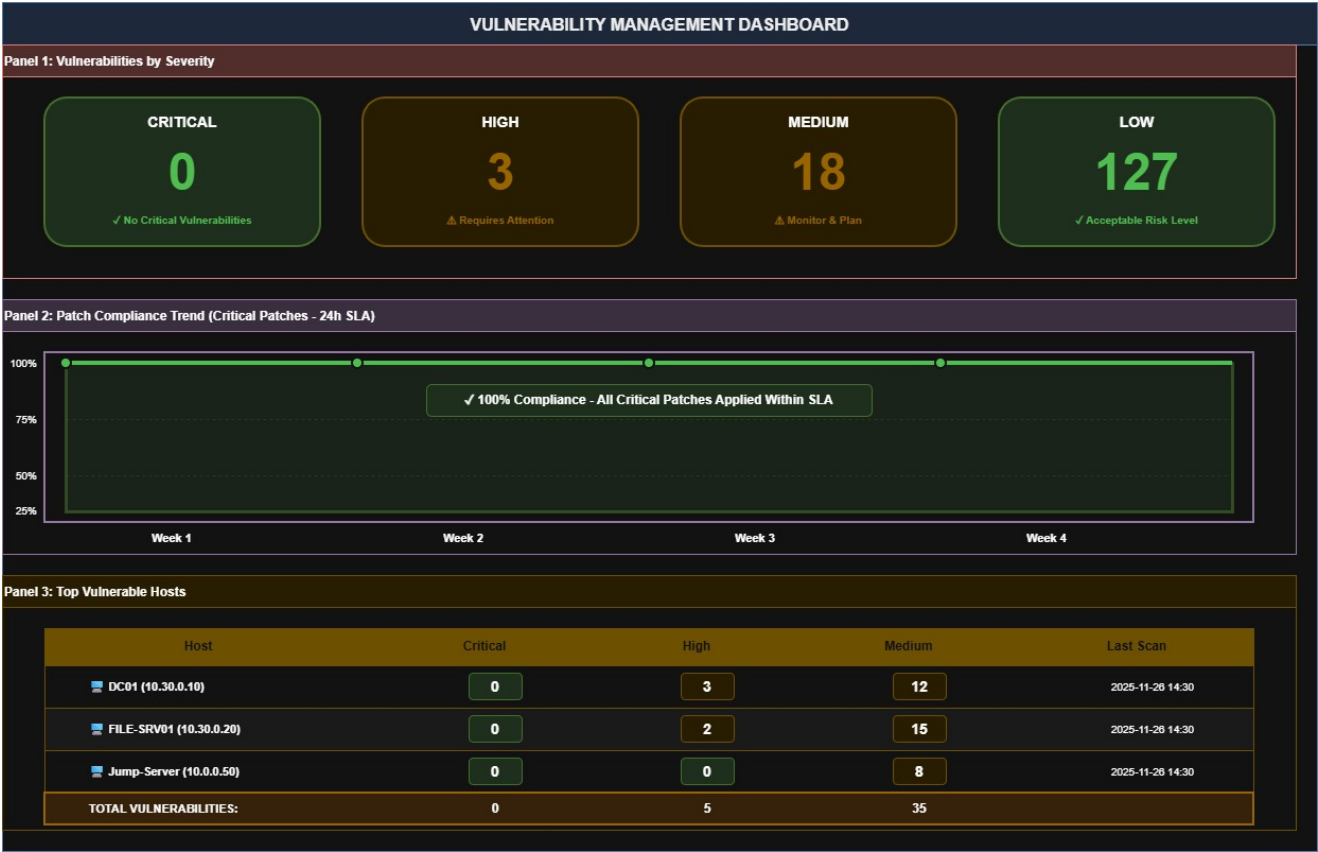
---

### Planned Splunk Dashboard Designs (Phase 1)

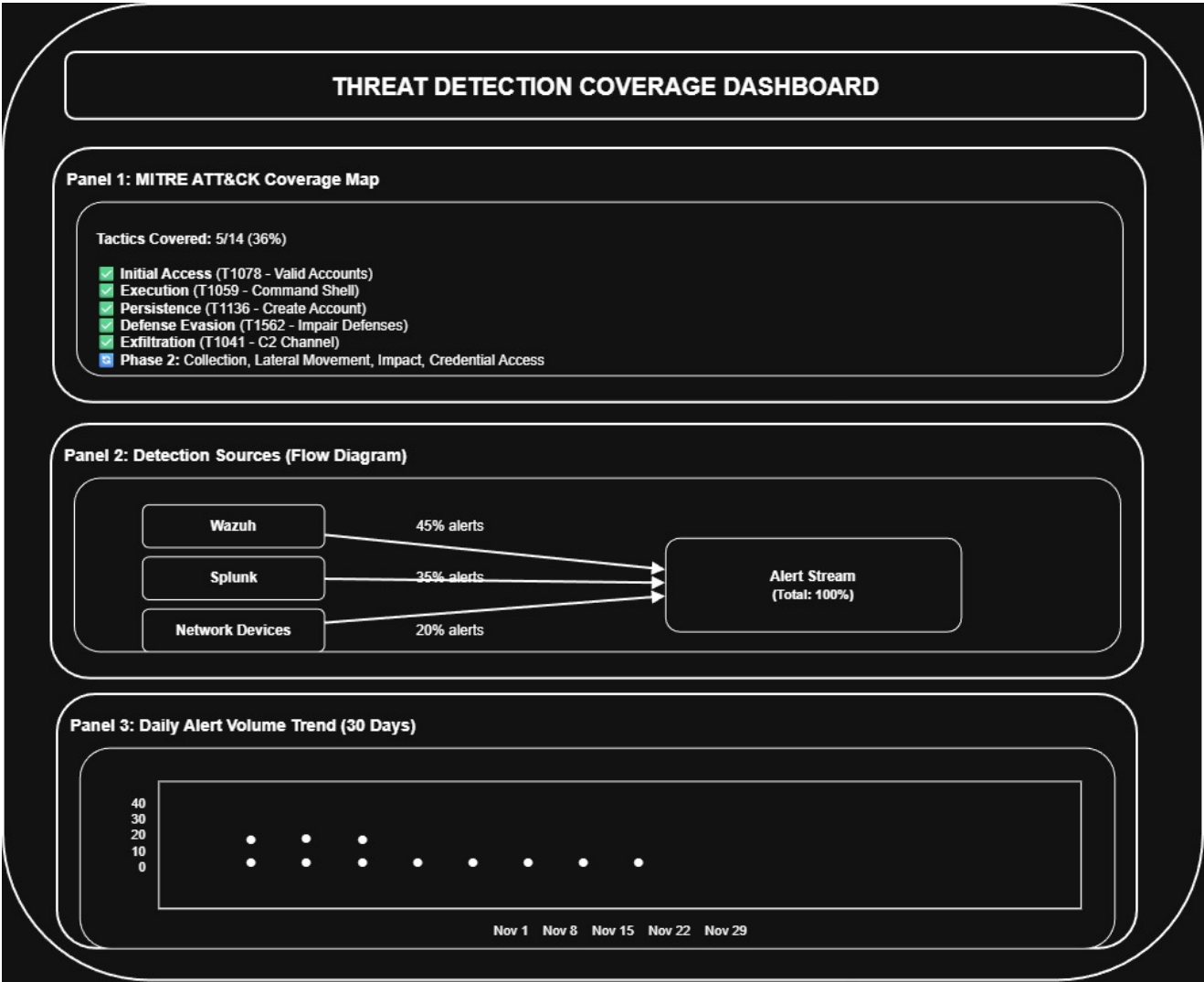
Dashboard 1: SOC Operations Overview



Dashboard 2: Vulnerability Management

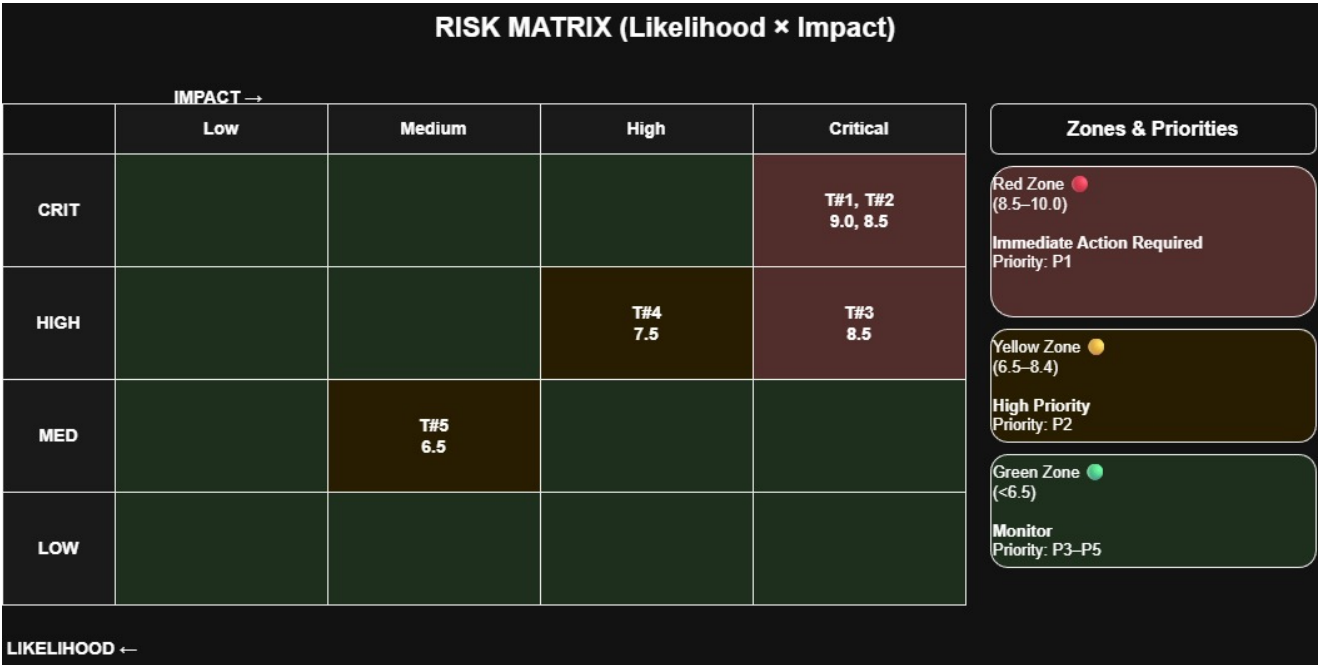


Dashboard 3: Threat Detection Coverage



# APPENDIX C: RISK HEAT MAP

## Risk Visualization Matrix

<